Görev-1

Bu çalışma kapsamında Kali makinesinden Windows 10 SCADA makinesine yönelik bir RDP brute-force saldırısı gerçekleştirilmiş, hem başarısız hem de başarılı oturum açma denemeleri üretilmiştir. Oluşan Windows Event logları Splunk üzerine aktarılmış ve bu logların analizi yapılarak saldırının gerçekten kaba kuvvet (brute-force) aktivitesi olup olmadığı kanıtlanmıştır.

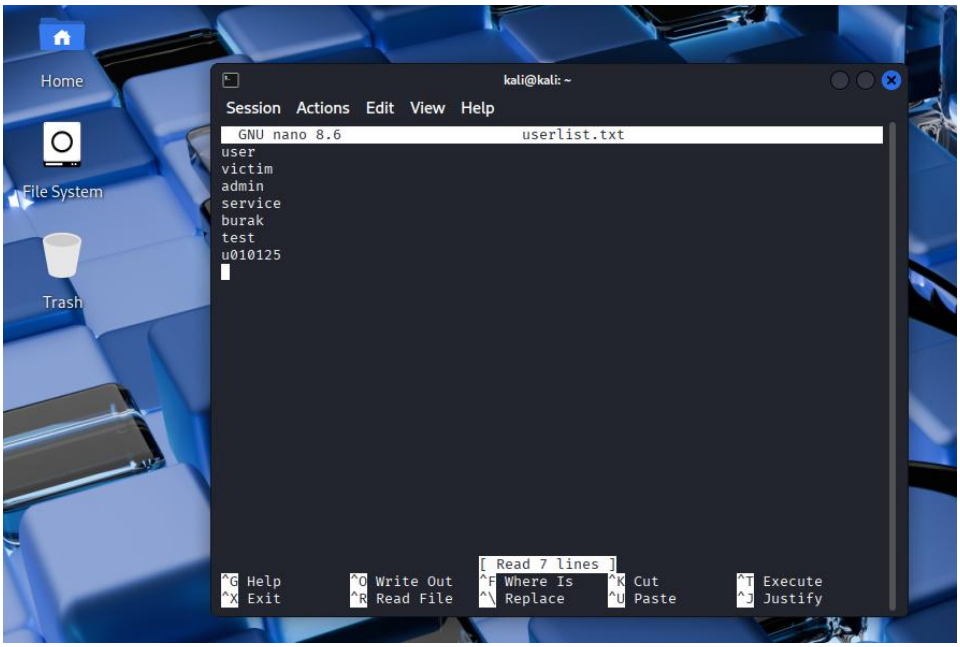
SALDIRI SENARYOSUNUN HAZIRLANMASI

Brute-force saldırısının gerçekçi ve anlamlı log üretebilmesi için Kali makinesinde üç temel hazırlık yapılmıştır: kullanıcı listesi oluşturma, parola listesi oluşturma ve Hydra ile saldırının başlatılması.

- **Kullanıcı Listesinin Oluşturulması**

Saldırganların olası kullanıcı adlarını topluca denemesini simüle etmek için bir wordlist dosyası hazırlanmıştır:

```
┌──(kali㉿kali)-[~]
└─$ nano userlist.txt
```



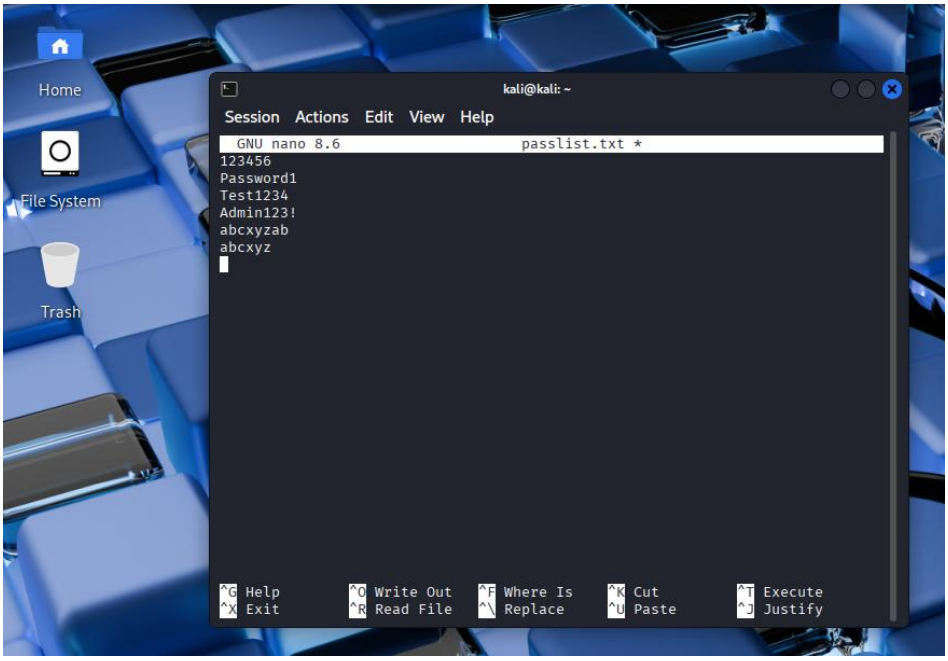
Şekil 1 Kali makinesinde 'nano userlist.txt' komutunu girip oluşturduğumuz kullanıcı listeleri

- **Parola Listesinin Oluşturulması**

Hydra'nın aynı şekilde çoklu parola denemesi yapabilmesi için yaygın/parola tahminlerine uygun bir şifre wordlist'i oluşturulmuştur:

┌──(kali㉿kali)-[~]

└─$ nano passlist.txt



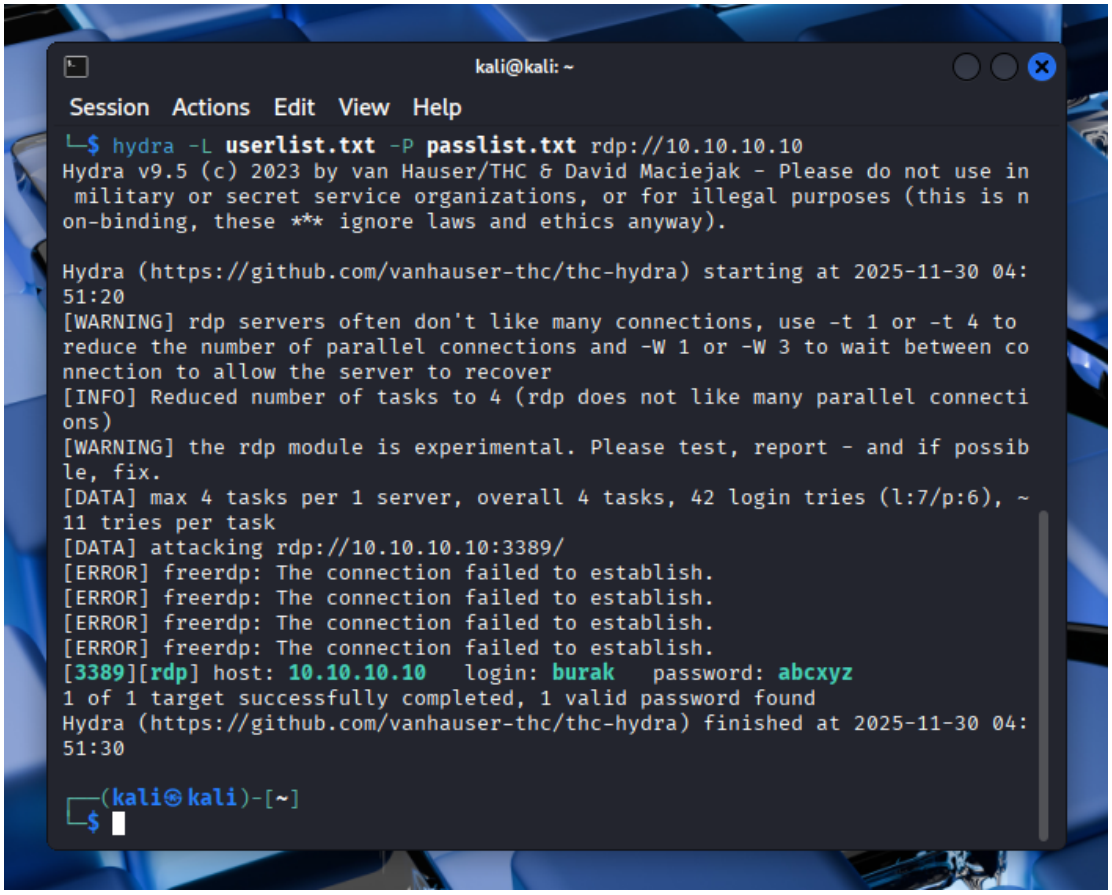
Şekil 2 Kali makinesinde 'nano passlist.txt' komutunu girip oluşturulan şifreler listesi

- **Hydra ile RDP Brute-Force Saldırısının Başlatılması**

Hazırlanan kullanıcı ve parola listeleri ile SCADA makinesine (10.10.10.10) karşı aşağıdaki Hydra komutu çalıştırılmıştır:

┌──(kali㉿kali)-[~]

└─$ hydra -L userlist.txt -P passlist.txt rdp://10.10.10.10



Şekil 3 Hydra ile RDP brute-force saldırısı

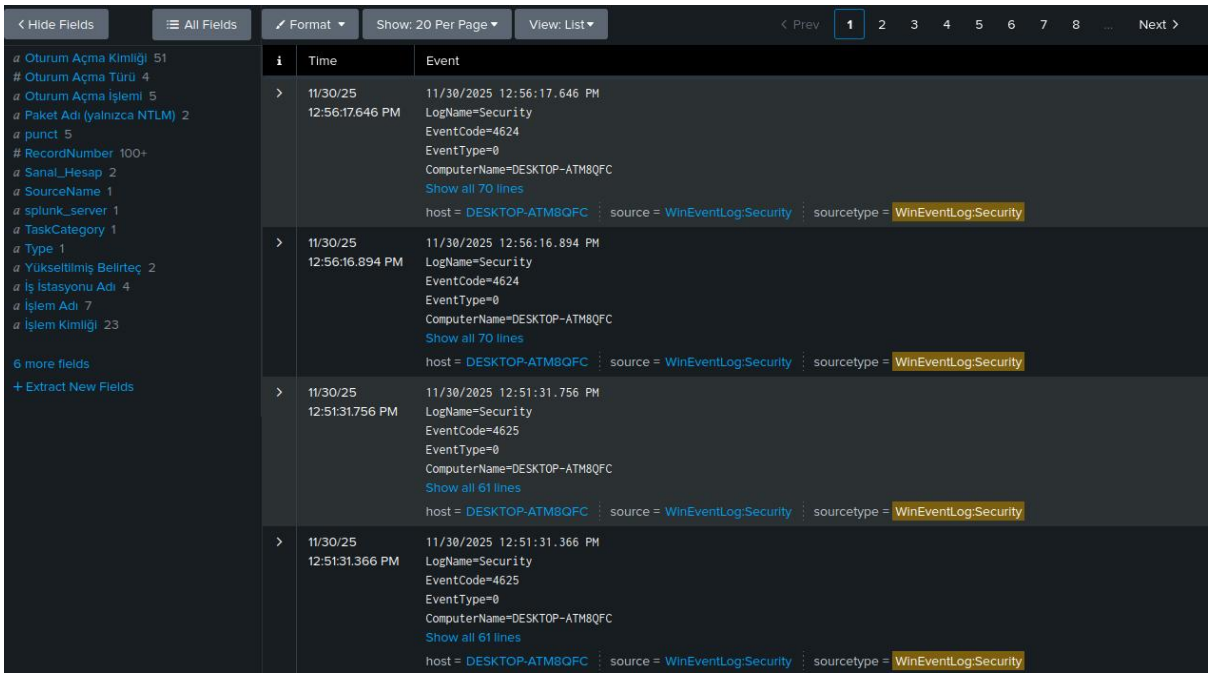
Hazırlanan kullanıcı ve parola listeleri kullanılarak Hydra ile hedef SCADA makinesine (10.10.10.10) karşı RDP brute-force saldırısı başlatılmıştır. Hydra, listedeki tüm kombinasyonları deneyerek “burak / abcxyz” kimlik bilgisini başarılı şekilde tespit etmiş ve böylece saldırının brute-force olduğu doğrulanmıştır.

Splunk Görevleri

1) Ham Veri Analizi:

Hedef Windows 10 (SCADA) makinesine ait Security loglarında hem başarılı (4624) hem de başarısız (4625) oturum açma girişimlerini listelemek için aşağıda belirtilen sorgu kullanılmıştır. Sorgu sonuçları, brute-force saldırılarında tipik olarak görülen yüksek sayıda başarısız giriş denemeleri ile ardından gelen tek bir başarılı giriş örüntüsünü açık şekilde ortaya koymaktadır.

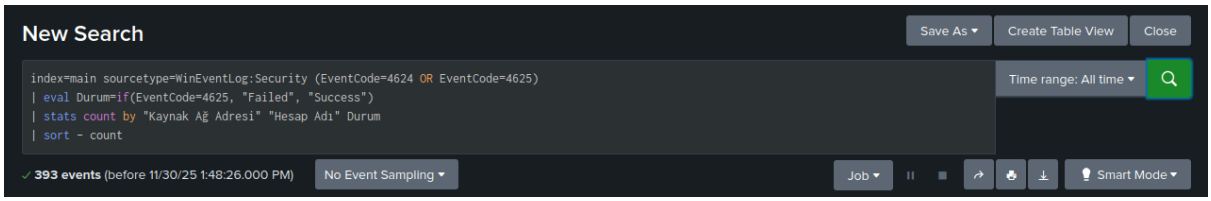
Şekil 4 Başarılı ve başarısız girişleri görmemizi sağlayan spl sorgusu



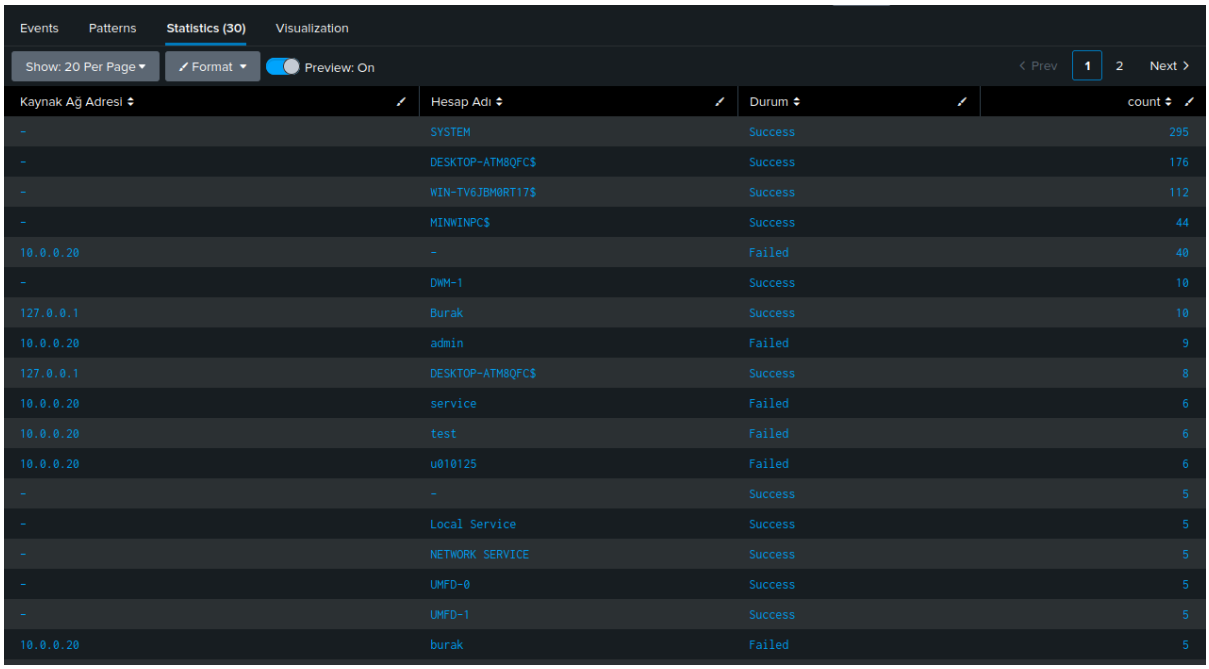
Şekil 5 Windows Security Loglarında Brute-Force Saldırısına Ait Başarısız (4625) ve Başarılı (4624) Oturum Açma Kayıtları

2) Saldırgan Profili Çıkarma (SPL Analizi):

Splunk üzerinde aşağıdaki SPL sorgusu çalıştırılarak başarısız (4625) ve başarılı (4624) oturum açma girişimleri duruma göre sınıflandırılmıştır:



Şekil 6 Saldırgan profili çıkarmamızı sağlayan SPL sorgusu



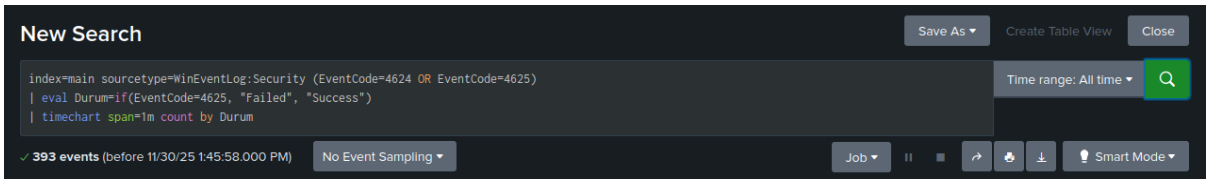
Kaynak Ağ Adresi	Hesap Adı	Durum	count
-	SYSTEM	Success	295
-	DESKTOP-ATM8QFC$	Success	176
-	WIN-TV6JBM0RT17$	Success	112
-	MINWINPC$	Success	44
10.0.0.20	-	Failed	40
-	DWM-1	Success	10
127.0.0.1	Burak	Success	10
10.0.0.20	admin	Failed	9
127.0.0.1	DESKTOP-ATM8QFC$	Success	8
10.0.0.20	service	Failed	6
10.0.0.20	test	Failed	6
10.0.0.20	u010125	Failed	6
-	-	Success	5
-	Local Service	Success	5
-	NETWORK SERVICE	Success	5
-	UMFD-0	Success	5
-	UMFD-1	Success	5
10.0.0.20	burak	Failed	5

Şekil 7 '4624/4625' olaylarına göre hesap adı ve kaynak IP bazlı giriş denemeleri

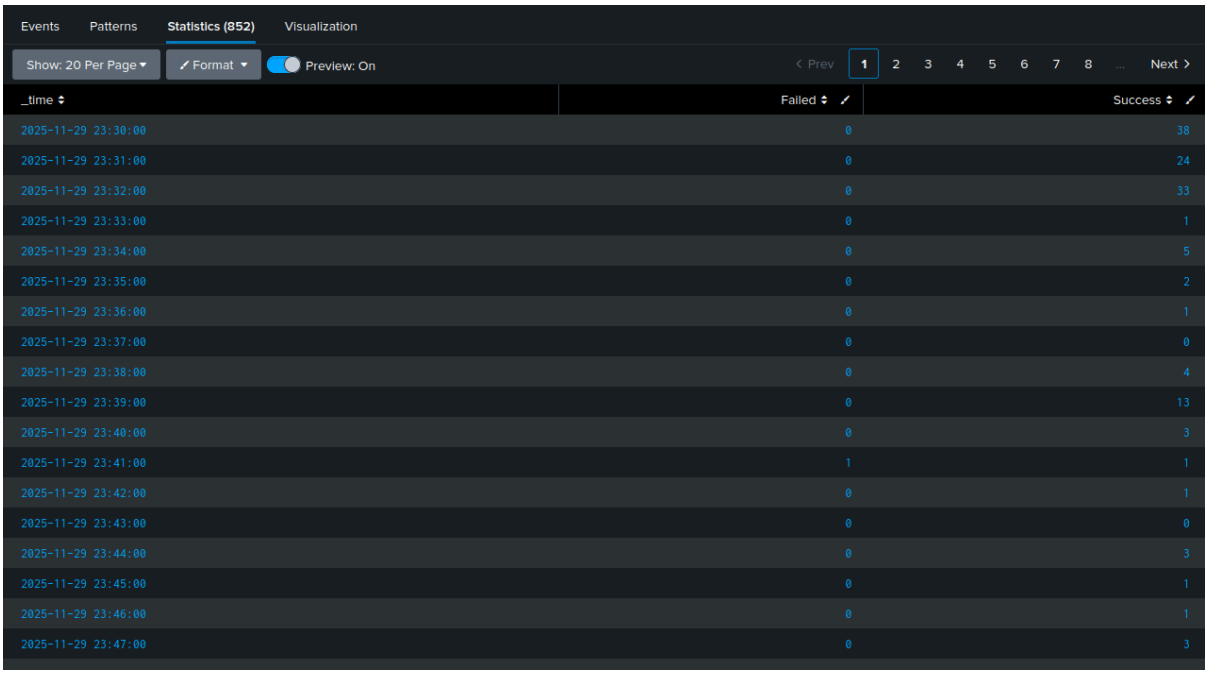
Yapılan SPL sorgusunda elde edilen tablo, saldırının 10.0.0.20 IP adresinden başlatıldığını açıkça göstermektedir. Bu IP, senaryoda Kali makinesi olup brute-force saldırısının kaynağıdır. Aynı IP adresinden kısa süre içinde birçok farklı kullanıcı adına (admin, service, test, u010125, burak) ait başarısız giriş denemeleri görülmektedir.Tablodaki veriler ayrıca saldırganın en sonunda "burak" hesabına ait doğru parolayı bulduğunu ortaya koymaktadır; çünkü bu hesap için hem başarısız hem de başarılı giriş kayıtları bulunmaktadır. Bu durum, kullanıcı hesabının brute-force yöntemiyle ele geçirildiğini doğrular.

3) Zaman Analizi:

Tabloda bazı dakikalarda çok sayıda başarılı giriş (Success) görülmesi, saldırganın doğru parolayı bulduktan sonra aynı hesabı arka arkaya otomatik olarak denediğini gösterir. Manuel bir kullanıcının bu kadar kısa sürede bu kadar fazla giriş üretmesi mümkün değildir. Bu davranış, saldırının otomatik bir brute-force aracıyla gerçekleştirildiğini açıkça kanıtlar.

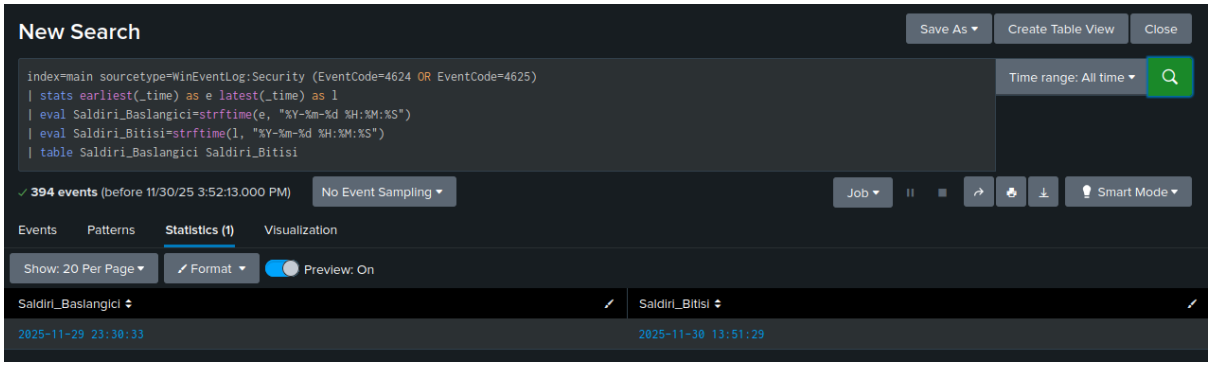


Şekil 8 Başarılı ve başarısız oturum açma denemelerinin dakika bazlı dağılımını gösteren SPL sorgusu



_time	Failed	Success
2025-11-29 23:30:00	0	38
2025-11-29 23:31:00	0	24
2025-11-29 23:32:00	0	33
2025-11-29 23:33:00	0	1
2025-11-29 23:34:00	0	5
2025-11-29 23:35:00	0	2
2025-11-29 23:36:00	0	1
2025-11-29 23:37:00	0	0
2025-11-29 23:38:00	0	4
2025-11-29 23:39:00	0	13
2025-11-29 23:40:00	0	3
2025-11-29 23:41:00	1	1
2025-11-29 23:42:00	0	1
2025-11-29 23:43:00	0	0
2025-11-29 23:44:00	0	3
2025-11-29 23:45:00	0	1
2025-11-29 23:46:00	0	1
2025-11-29 23:47:00	0	3

Şekil 9 Brute-force sonrası art arda gerçekleşen başarılı RDP girişlerinin zaman çizelgesi



Şekil 10 Saldırı zaman aralığının SPL sorgusu ile belirlenmesi

SPL sorgusu sonucunda saldırının 29 Kasım 2025 23:30:33 tarihinde başladığı ve 30 Kasım 2025 13:51:29 tarihinde sona erdiği görülmektedir.

SONUÇ

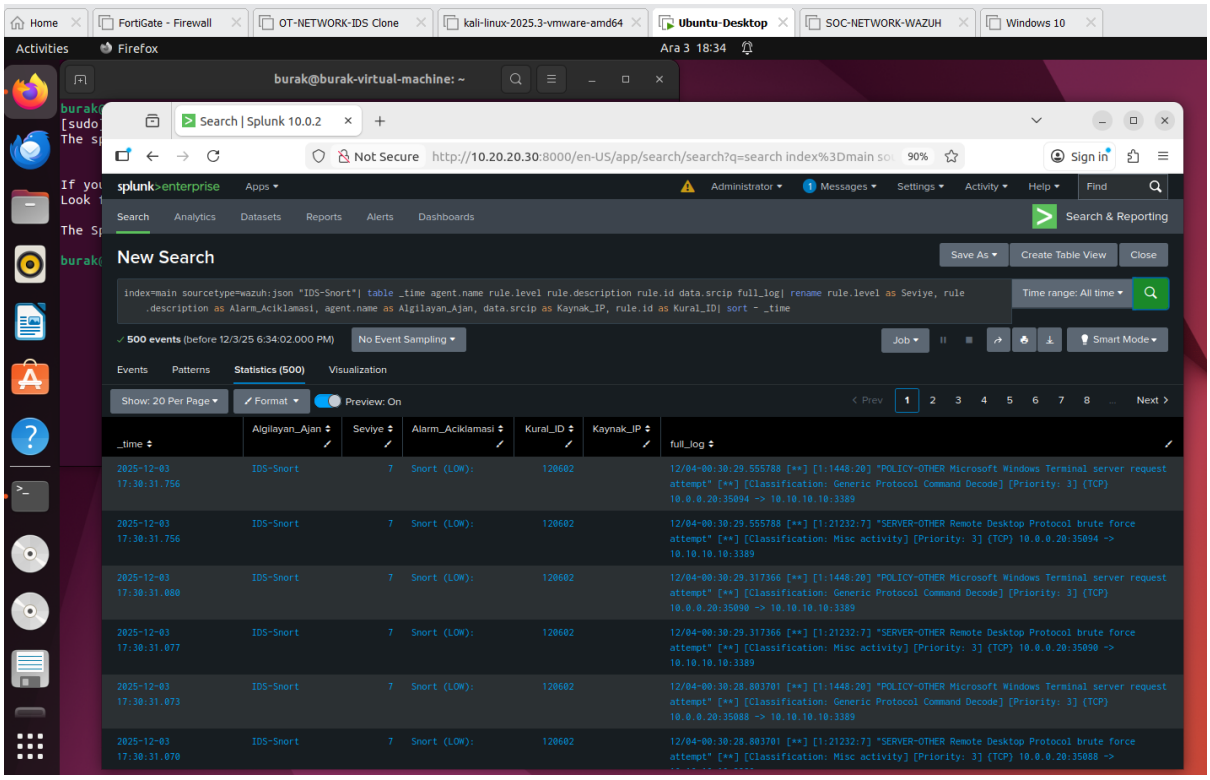
Splunk üzerinde yapılan analizler, Kali makinesinden gelen çoklu başarısız giriş denemeleri (4625) ve ardından gerçekleşen başarılı oturum açma (4624) kayıtlarıyla RDP brute-force saldırısını açıkça doğrulamıştır. “burak” hesabının doğru parolasının bulunması ve art arda başarılı girişlerin oluşması, saldırının otomatik bir araçla yürütülüp başarıya ulaştığını kanıtlamaktadır.

CBERNET HAFTALIK GÖREV-2

Bu görevde amaç, SCADA ağında gerçekleşen brute-force saldırısının yalnızca Windows uç noktasında değil, aynı zamanda savunma bileşenleri (Wazuh, Snort, Firewall) tarafından da algılanıp algılanmadığını doğrulamaktır.

1. Savunma Loglarını Bulma

Bir saldırının gerçekten kurum açısından kritik olup olmadığını anlayabilmek için sadece Windows üzerindeki başarısız girişleri görmek yeterli değildir. Aynı zamanda savunma sistemlerinin bunu fark edip etmediğini ve hangi seviyede alarm ürettiğini görmek gerekir. Bu nedenle ilk iş olarak Wazuh/Snort loglarının Splunk'a gelip gelmediğini doğrularız.



Şekil 11 Wazuh Savunma Loglarından Ham Verinin SPL ile Çıkarılması

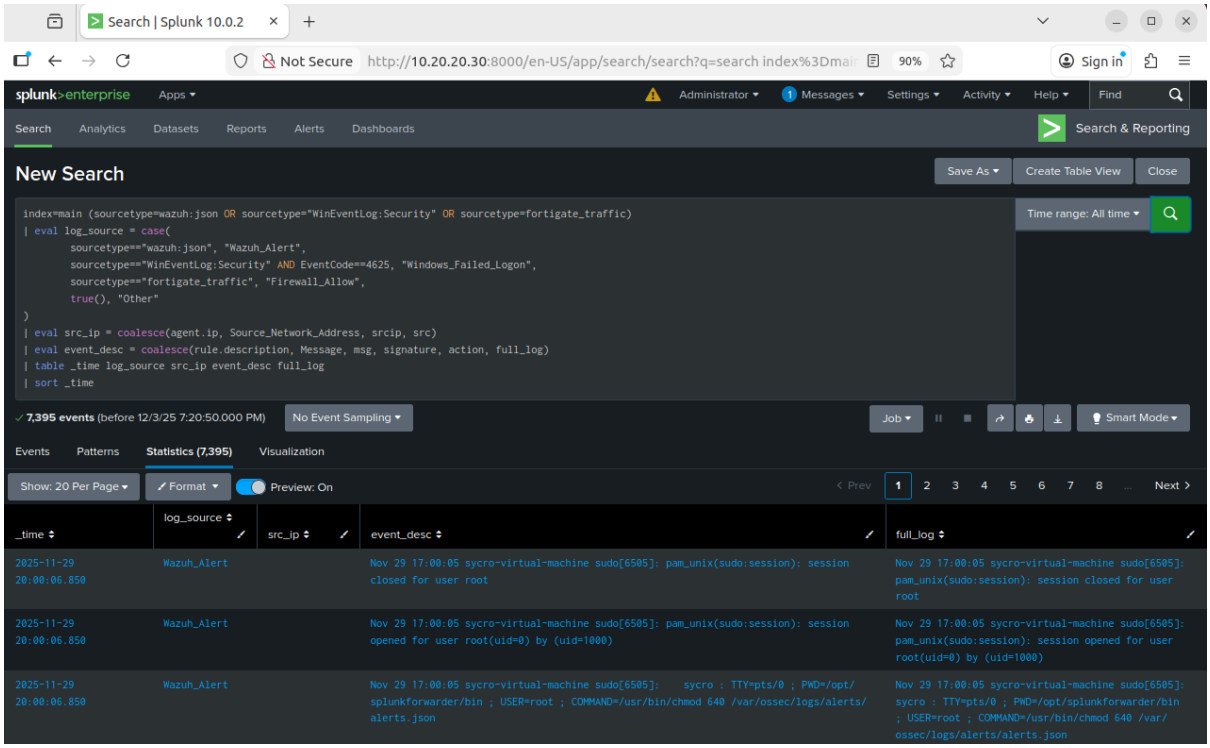
Şekil 1'de, Wazuh üzerinden gelen IDS-Snort alarmları doğrudan parse edilebilir JSON formatında olduğu için ek bir ayrıştırma gerekmemiş, tablo görünümü oluşturmak için ilgili alanlar SPL içerisindeki table komutu ile seçilmiştir. Bu sorgu sayesinde her alarm kaydının zamanı, algılayan ajan adı (IDS-Snort), alarm seviyesi, alarm açıklaması, kural ID'si ve kaynak IP bilgisi düzenli bir formatta listelenmiştir. Ayrıca rename komutu kullanılarak alan isimleri daha anlaşılır hale getirilmiş, böylece SOC analisti açısından alarmın hangi kural

tarafından tetiklendiği, hangi IP'den geldiği ve alarmın şiddeti hızlı şekilde yorumlanabilir hale gelmiştir. Görselde de görüldüğü üzere, Snort tarafından üretilen brute-force ve kötü amaçlı RDP denemeleri detaylı şekilde kayıt altına alınmıştır.

Ayrıca çalıştırdığımız SPL sorgusunda da görüldüğü gibi sistemin servis başlatma, oturum açma/kapama ve hata durumlarını doğru şekilde raporladığı görülüyor; bu da savunma mekanizmasının aktif olduğunu bizlere göstermektedir.

2. Korelasyon (Çapraz Sorgu-SPL Kullanımı):

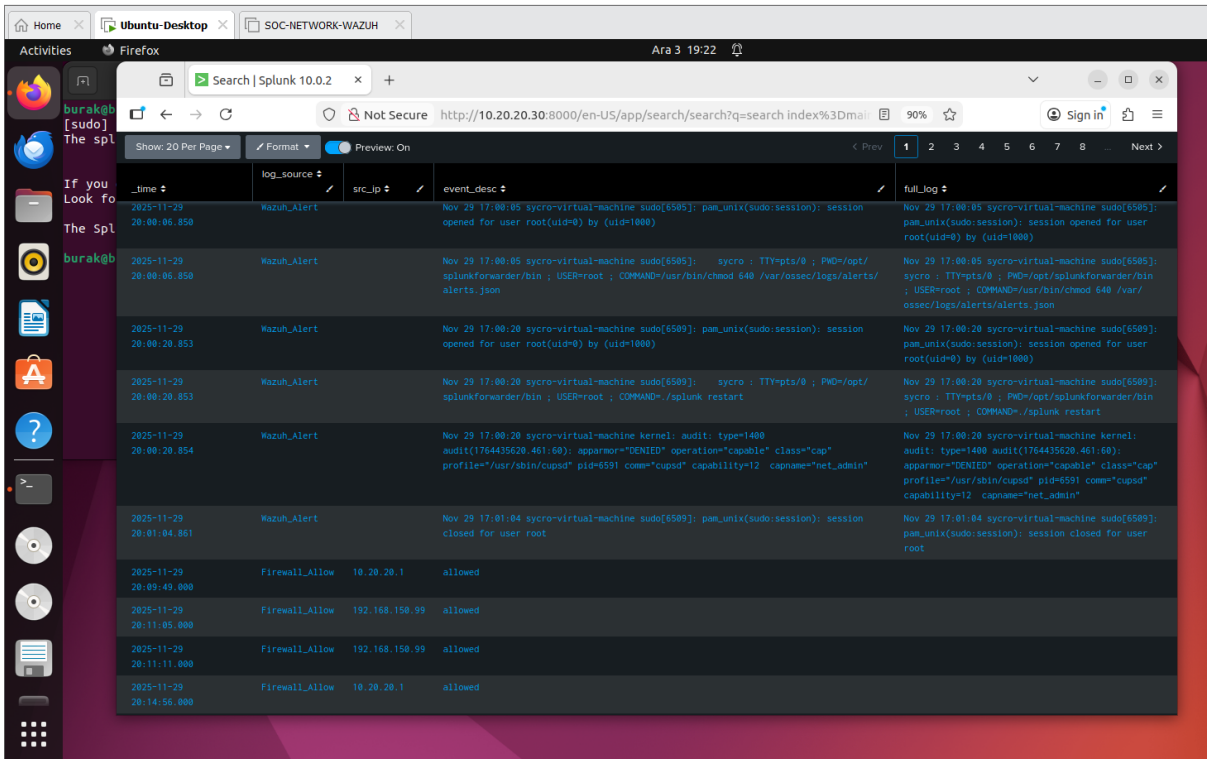
SCADA ortamında gerçekleşen brute-force saldırısının yalnızca uç nokta (Windows) üzerinde görülmesi yeterli değildir; saldırının farklı güvenlik katmanlarında da aynı zaman diliminde tespit edilip edilmediğinin doğrulanması gerekir. Korelasyon analizinin temel amacı, Windows üzerindeki başarısız oturum açma denemeleri ile Wazuh/Snort tarafından üretilen alarmların zaman bakımından örtüşüp örtüşmediğini tespit etmektir.



Şekil 12 Çapraz Log Korelasyonu – SPL Sorgusu ve Çıktısı

Şekil 2'de görülen korelasyon sorgusu, Wazuh Alert, Windows Security Logları ve Fortigate Firewall kayıtlarını aynı arama içerisinde bir araya getirerek farklı güvenlik katmanlarından üretilen olayları tek bir zaman akışında toplamaktadır. Sorguda kullanılan log_source alanı,

her bir logun hangi kaynaktan geldiğini açık şekilde etiketleyerek olayın firewall, uç nokta veya Wazuh tarafından mı üretildiğini netleştirmektedir. src_ip alanı, Wazuh, Windows ve Firewall loglarında farklı isimlerle geçen IP adreslerini coalesce() fonksiyonu yardımıyla tek bir ortak IP alanında birleştirmektedir. Benzer şekilde, alarm açıklamaları, Windows güvenlik mesajları, Snort imzaları ve firewall action bilgileri event_desc içinde normalize edilmiştir. Böylece tüm sistemlerden gelen olaylar tek bir açıklama formatında okunabilir hale getirilmiştir.

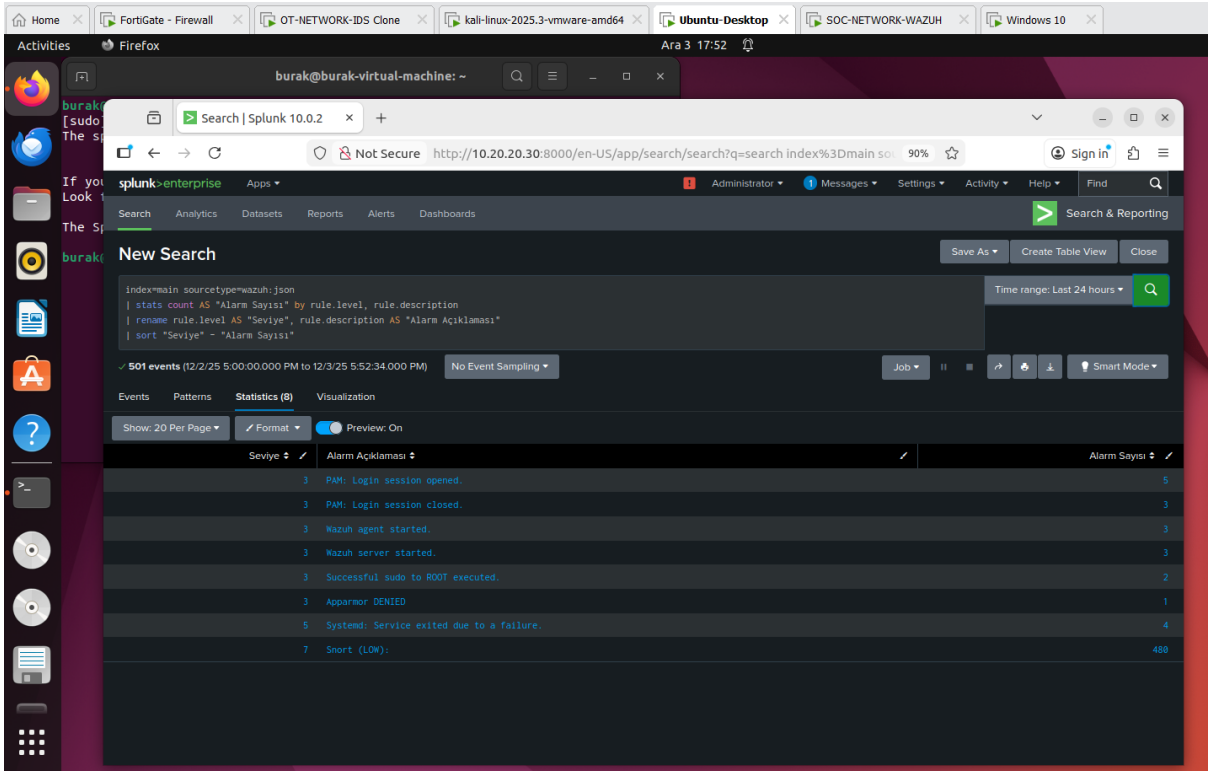


Şekil 13 Çapraz Log Analizi

Şekil 3'te, Firewall'ın Allow olarak işaretlediği bağlantıların tek zaman çizgisinde listelendiği ve saldırgan IP'nin SCADA ağına giriş yaptığı anların görüntülendiği görülmektedir. Bu trafik daha sonra Wazuh alarmlarıyla eşleşerek, firewall'dan geçiş yapan bağlantının savunma sistemi tarafından "Alert" olarak işaretlendiği başarıyla doğrulanmıştır.

3. Alarm Doğrulama:

Bu görev, Wazuh'un ürettiği alarmları seviye ve açıklama bazında gruplandırarak her alarm türünün kaç kez meydana geldiğini göstermektedir.



Şekil 14 Wazuh Alarm Sınıfı ve Tetiklenme Sayıları

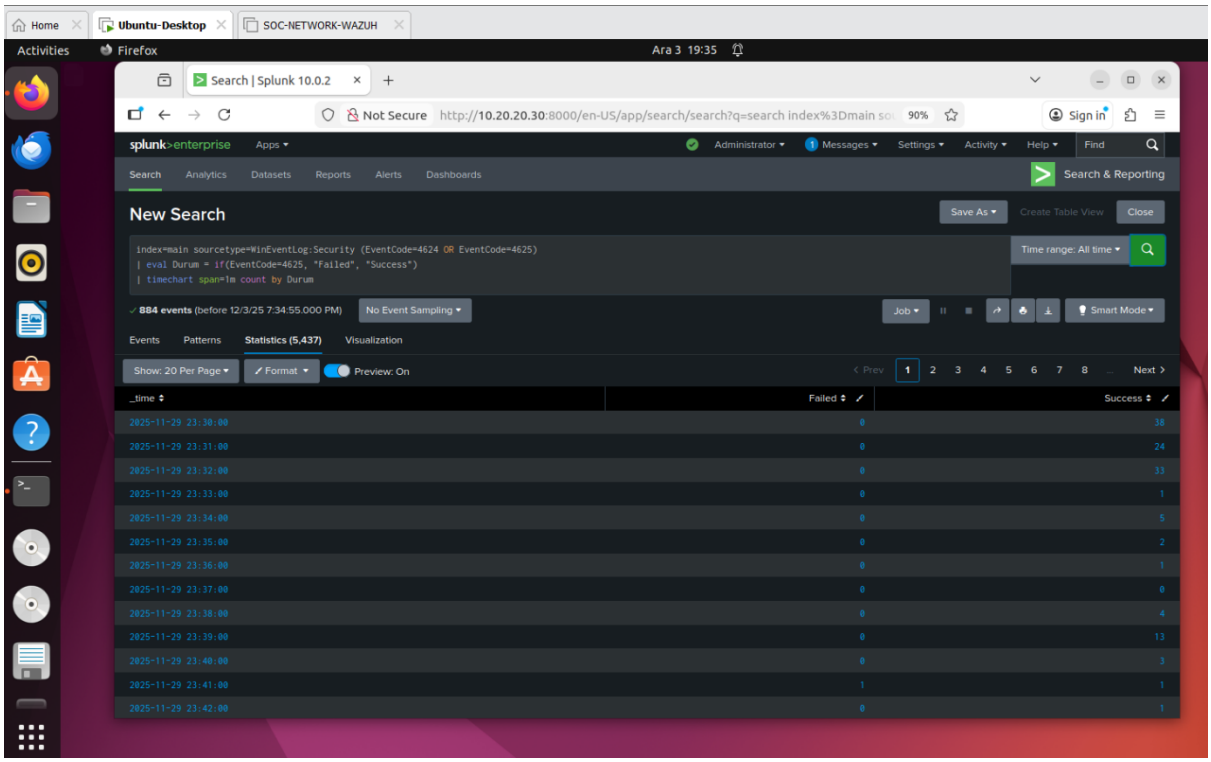
Görüntüde alarmların büyük çoğunluğunun Seviye 3 seviyesinde toplandığı görülmektedir. Bu alarmlar çoğunlukla oturum açma/kapatma, Wazuh agent başlatılması gibi düşük önemdeki sistemsel olaylardan oluşmaktadır. Seviye 5 seviyesinde yalnızca bir adet servis hatası bulunması, kritik seviyede bir güvenlik problemi olmadığını göstermektedir. Buna karşın, Snort tarafından üretilen Level 7 alarmların yüksek sayıda olması, ağ üzerinde şüpheli veya saldırı niteliğinde aktivitelerin yoğun biçimde tespit edildiğine işaret etmektedir.

HAFTALIK GÖREV-3

Bu görevin amacı, Görev 1 ve Görev 2'de elde edilen tüm analizleri teknik log satırlarından bağımsız olarak, SOC yöneticisinin tek bakışta saldırının boyutunu, kaynağını ve savunma sistemlerinin verdiği tepkileri anlayabileceği görsel bir operasyon paneli hâline getirmektir.

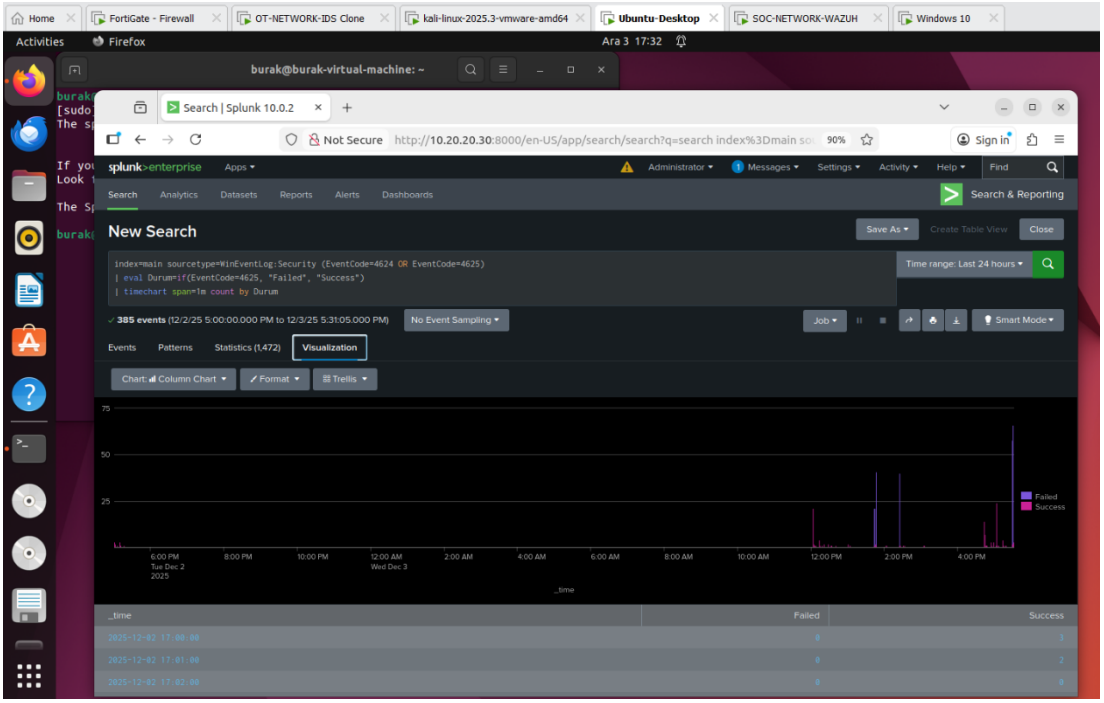
1. Panel: Saldırının Uç Nokta Özeti (Görev 1)

Bu panelin amacı, brute-force saldırısının uç noktada nasıl bir etki yarattığını zaman boyutunda görselleştirerek saldırının ne zaman başladığını, hangi dönemlerde yoğunlaştığını ve kullanıcıların hangi aralıkta risk altında olduğunu hızlı şekilde ortaya koymaktır. Timechart tabanlı çizgi grafik sayesinde başarısız ve başarılı oturum açma girişleri karşılaştırmalı olarak görüntülenir ve SOC analisti saldırının pik yaptığı dakikaları tek bakışta tespit edebilir.



Şekil 15 Zaman Bazlı Giriş Denemelerinin Dağılımı (4624/4625)

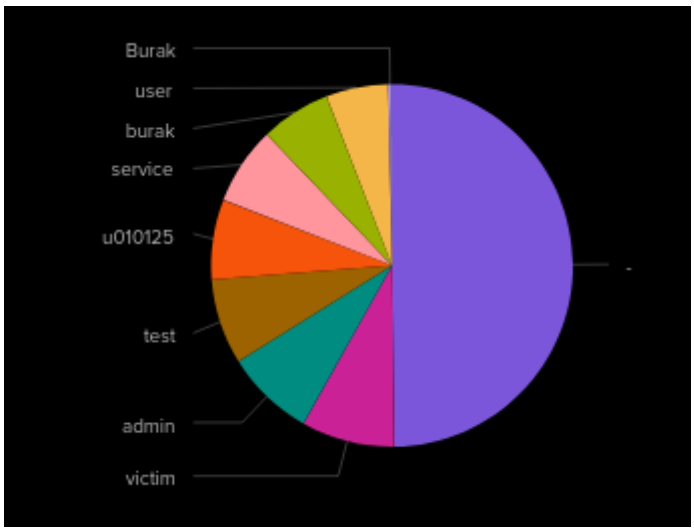
Şekil 5'te, Windows Security loglarında kaydedilen başarılı (4624) ve başarısız (4625) oturum açma girişlerini dakika bazında özetleyerek saldırının yoğun olduğu zaman aralıklarını veri düzeyinde göstermektedir.



Şekil 16 Dakika Dazında Giriş Denemeleri – Dashboard Zaman Çizelgesi

Şekil 6'da grafik, başarılı ve başarısız login girişlerini zamana göre karşılaştırmalı olarak görselleştirerek saldırının davranışını çok net şekilde ortaya koymaktadır.

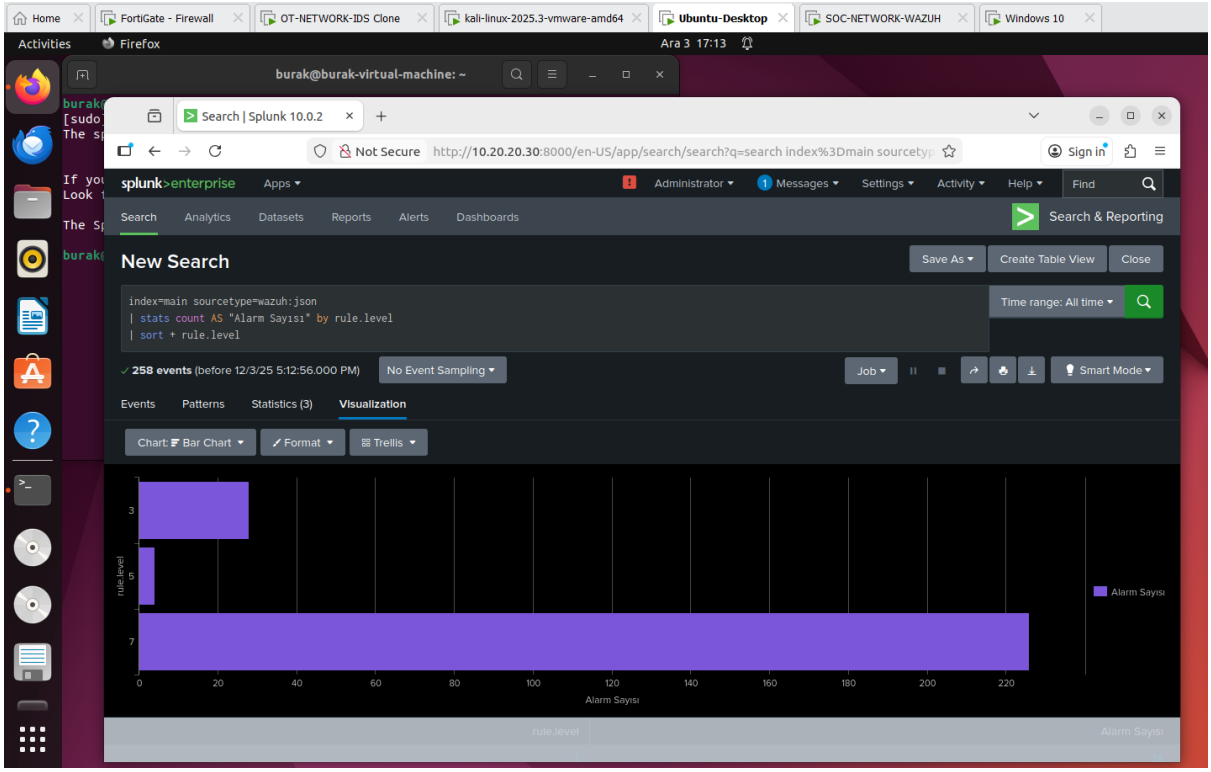
Pie chart, brute-force saldırısı sırasında en çok hedef alınan kullanıcı hesaplarını oranlara göre göstererek saldırının odaklandığı hesapları tek bakışta tespit etmeyi sağlar. Grafikte belirli bir kullanıcının yüksek bir paya sahip olması, saldırganın özellikle o hesaba yoğunlaştığını ve bu hesabın risk seviyesinin daha yüksek olduğunu gösterir.



Şekil 17 En Çok Denenen Kullanıcı Hesapları Dağılımı

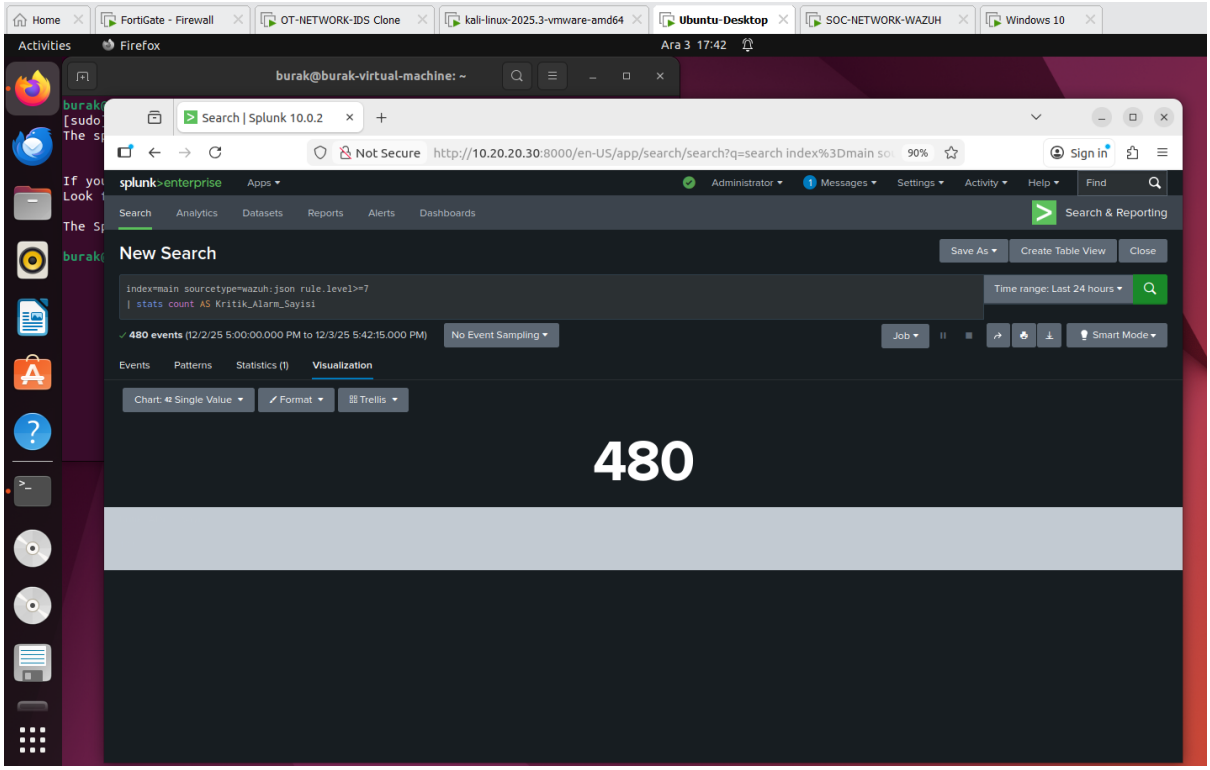
2. Panel: Savunma ve Alarm Durumu (Görev 2)

Bu panelin amacı, güvenlik cihazlarımızın saldırıyı tespit edip etmediğini ve olayın kritik düzeyde olup olmadığını hızlı bir şekilde değerlendirmektir. Wazuh tarafından üretilen alarm seviyeleri analiz edilerek sistemdeki uyarıların ciddiyeti görselleştirilmiş, ayrıca toplam "Kritik Alarm" sayısı tekil değer paneliyle yöneticilere anlık durum farkındalığı sağlanmıştır. Bu panel sayesinde SOC analisti saldırının hangi aşamada fark edildiğini ve güvenlik altyapısının tehdide verdiği tepkinin yeterliliğini tek bakışta görebilir.



Şekil 18 Wazuh Alarm Seviyesi Dağılım Grafiği

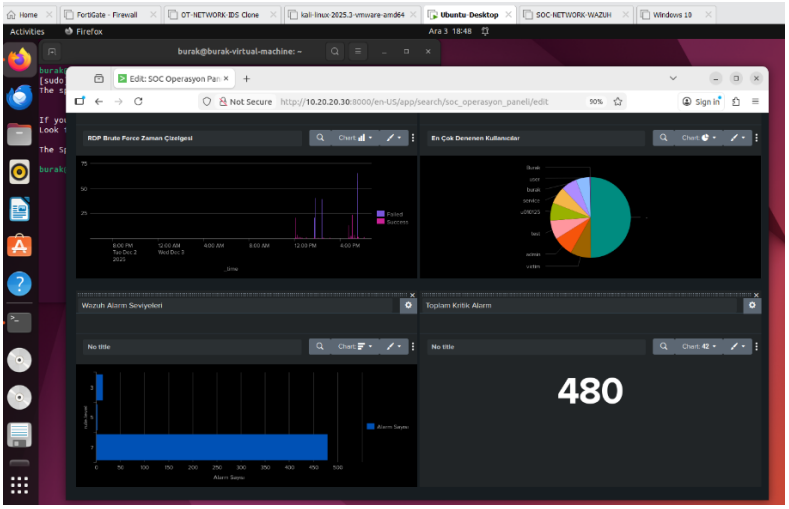
Şekil 8'de görüldüğü üzere Wazuh alarm dağılımında en yüksek yoğunluk Seviye 7 kategorisindedir. Bu seviye, grafik üzerinde çok belirgin şekilde diğer alarm seviyelerinin üzerinde yer almaktadır. Seviye 3 ve Seviye 5 alarmları ise daha düşük sayılarda gözlemlenmiştir. Bu durum, ortamda özellikle Seviye 7 tipindeki olayların baskın olduğunu ve analizde öncelikli olarak ele alınması gereken alarm grubunun bu kategori olduğunu göstermektedir.



Şekil 19 Toplam Kritik Alarm Sayısı

Toplam Kritik Alarm paneli, Wazuh tarafından üretilen ve güvenlik açısından yüksek öneme sahip olan kritik seviyedeki tüm alarm kayıtlarının toplamını tek bir değer şeklinde göstermektedir. Bu panel sayesinde SOC analisti, ortamdaki kritik tehdit yoğunluğunu anlık olarak takip edebilir ve alarm seviyesindeki ani artışlara hızlı şekilde tepki verebilir.

3. Panel: Görsel Düzenleme ve Sunum (Final)



Şekil 20 Final Dashboard